

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

PROCEDURA PRIVACY BY DESIGN E BY DEFAULT

Integrazione dei principi di protezione dei dati
fin dalla progettazione e per impostazione predefinita

Codice	Revisione	Data	Pagine
TD-SGI-PRO062_00	00	16/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
RSGI	Direzione Generale	Interno	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
16/04/2026	16/04/2026	16/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

GDPR N. 679/2016

Premesse Normative

Al fine di adottare misure tecniche ed organizzative adeguate (pseudonimizzazione, cifratura, etc.) volte ad attuare in modo efficace i principi di protezione dei dati ed a integrare nel trattamento le garanzie necessarie al fine di soddisfare i requisiti del regolamento e tutelare i diritti degli interessati, gli elementi da considerare sono:

- Stato dell'arte
- Costi di attuazione
- Natura, ambito di applicazione, contesto, finalità del trattamento
- Rischi aventi probabilità e gravità diverse per diritti e libertà delle persone fisiche (sia al momento di determinare i mezzi del trattamento che all'atto del trattamento)

È obbligo del titolare trattare per impostazione predefinita solo i dati personali necessari per ogni specifica finalità del trattamento, per quanto riguarda:

- Quantità di dati personali raccolti
- Portata del trattamento
- Periodo di conservazione
- Accessibilità

È necessario che siano messe in atto misure tecniche ed organizzative che garantiscano la non accessibilità ai dati personali ad un numero indefinito di persone fisiche senza l'intervento della persona fisica.

Sintesi dei Principi

Il principio sulla protezione dei dati per impostazione predefinita potrebbe essere applicato:

- Ai sistemi informativi
- Ai processi di business
- Alla definizione strutturale degli edifici e delle infrastrutture

Al fine di aderire al principio di protezione dei dati per impostazione predefinita è necessario eseguire una valutazione del rischio in ambito privacy in tutti i casi in cui venga definito un nuovo processo, implementato un nuovo sistema o si debba reingegnerizzare i processi di business, prevedendo, se necessario, specifiche misure organizzative e/o tecnologiche.

Azioni Preliminari

- Diffusione preventiva all'interno dell'organizzazione dei concetti di Privacy by Design e Privacy by Default
- Formalizzazione di regole che sanciscano l'obbligo di informare direzione e DPO nel caso di avvio di nuovi progetti o sviluppo di iniziative già presenti
- Determinazione di tempistiche precise per le attività di cui alla procedura dedicata
- Predisposizione di moduli da utilizzare per seguire gli step di cui alla procedura (disponibili nella procedura TD-SGI-PRO063_00 - DPIA)
- Definizione di un calendario periodico di revisione delle misure di protezione adottate, con frequenza almeno annuale

Fasi Organizzative

- Ideazione di un progetto o implementazione di un prodotto/servizio sussistente che comporti il trattamento di dati personali, considerando l'impatto privacy mediante preventiva identificazione di: attività chiave, partners chiave, risorse chiave, struttura dei costi, bacino di soggetti interessati

- Definizione degli obiettivi
- Identificazione dei vantaggi per l'organizzazione e per l'utenza
- Verifica del ruolo dell'utente (approccio user-centric) e dell'impatto sul loro diritto alla riservatezza
- Convocazione di una riunione con i comparti organizzativi interessati e con il DPO
- Verifica degli impatti sulla tutela dei dati personali connessi con il progetto sulla base di: natura, ambito di applicazione, finalità, contesto del trattamento
- Valutazione della struttura organizzativa, fisica ed informatica esistente al fine di delineare l'adeguatezza rispetto alla protezione dei dati personali
- Individuazione/scelta dei mezzi utili all'iniziativa
- Verifica circa la necessità di interventi formali sulle informazioni già fornite o da fornire agli interessati
- Acquisizione dei consensi ulteriori eventualmente necessari a legittimare il trattamento
- Confronto con i fornitori dei mezzi per vagliare l'adeguatezza rispetto alla tutela della riservatezza dei soggetti interessati
- Analisi degli eventuali costi aggiuntivi da sostenere per implementare l'assetto esistente
- Valutazione costi/benefici
- Valutazione dei rischi connessi in termini di tutela dei dati personali
- Impostazione delle misure di sicurezza atte a prevenire e scongiurare il manifestarsi dei rischi individuati
- Formalizzazione delle decisioni assunte e del processo decisionale seguito
- Finalizzazione del progetto nuovo o già esistente
- Informativa all'organizzazione affinché iniziative/progetti simili futuri seguano i principi di tutela della riservatezza sviluppati nella fattispecie
- Presidio delle misure di sicurezza adottate rispetto ad eventuali evoluzioni tecnologiche o di altra natura correlate all'iniziativa

Trigger DPIA - Obbligatorietà della Valutazione di Impatto

Una Data Protection Impact Assessment (DPIA) è obbligatoria quando il trattamento comporta:

- Elaborazione sistematica e su larga scala per il monitoraggio di soggetti interessati
- Trattamento su larga scala di categorie speciali di dati (dati sensibili)
- Monitoraggio sistematico di aree pubbliche su larga scala
- Utilizzo di nuove tecnologie che comportano rischi elevati per i diritti e le libertà
- Trasferimenti di dati verso paesi terzi o organizzazioni internazionali

Gestione di Conflitti Budget vs Privacy

In caso di conflitto tra vincoli di budget e requisiti privacy, il DPO sottopone la questione alla Direzione Generale per decisione motivata, da documentare nel registro delle decisioni. Tale decisione deve bilanciare le esigenze economiche dell'organizzazione con i rischi per i diritti e le libertà degli interessati.

Scope di Applicazione

La presente procedura si applica a tutti i nuovi progetti, implementazioni di prodotti/servizi, reingegnerizzazioni di processi e evoluzioni tecnologiche che comportino il trattamento di dati personali da parte dell'organizzazione.